Meridian CRM

Implementation Plan v3 — Configurable, multi-industry CRM platform with a Migration Agency industry pack

Version	3.0 — supersedes v2 (migration-only CRM)
Date	3 November 2026
Product name	“Meridian CRM” is a working name; the brand name, logo and colours are configurable settings
Backend	Python 3.12 · FastAPI · SQLAlchemy 2 · Alembic · Celery + Redis
Frontend	React 18 · TypeScript · Vite · TanStack Query · Tailwind CSS
Database	Neon serverless PostgreSQL (AWS Sydney)
Apps	Sales · Service · Marketing · Billing (products & invoicing) · Analytics · Setup
Customisation	Custom fields and custom objects, full list views, configurable apps & tabs
Industry pack	Migration Agency (Australia) — built on the same customisation engine

Contents

1. What changed from v2
2. Goals and scope
3. Architecture: the metadata engine
4. Customisation: objects, fields, relationships
5. Standard objects
6. Apps, navigation and user interface
7. List views, record pages, search, import/export
8. Business logic of the standard apps
9. Security model: profiles, roles and sharing
10. Default profiles and permission matrix
11. Migration Agency industry pack
12. Reports and dashboards
13. Data model and API
14. Platform security, compliance, performance
15. Testing, Neon, deployment
16. Delivery phases
17. Risks and open questions

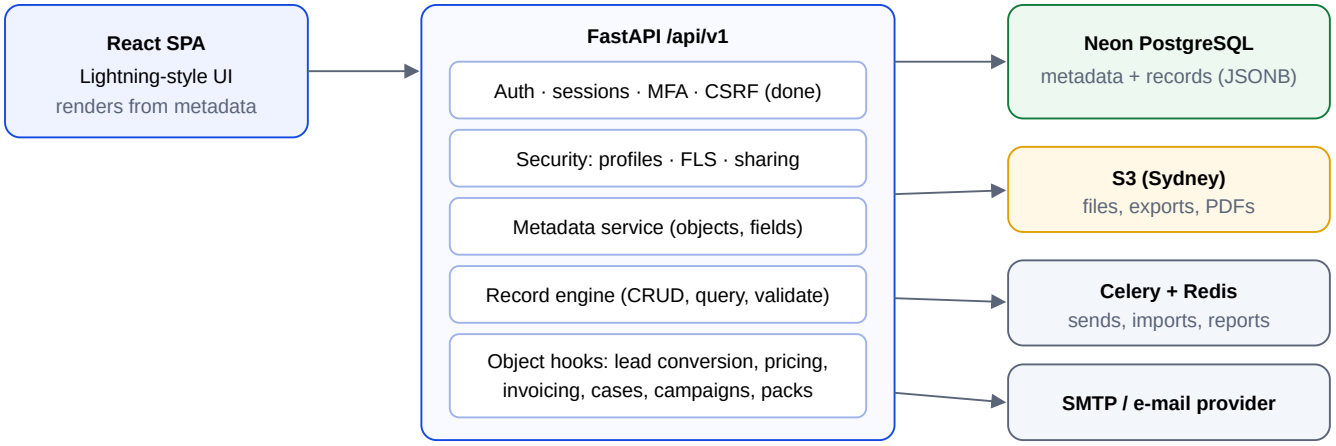
1. What changed from v2

Topic	v2	v3
Product	CRM built only for migration agents	General CRM for any industry. Migration agency becomes an optional **industry pack**.
Data model	Fixed tables per business object	**Metadata-driven engine**: standard and custom objects share one engine, so custom fields, list views, reports, search and permissions work the same for every object.
Access control	8 fixed roles in code	Admin-configurable **profiles** (object + field + system permissions), **role hierarchy** and **sharing settings**, with 8 default profiles. The migration roles become pack profiles.
Apps	One app	Sales, Service, Marketing, Billing, Analytics, Setup; apps and tabs are configurable.
UI	Top navigation	Lightning-style layout: left app rail, global search header, app tabs, list views, record pages with a stage path.
Kept from phases 0–1	Project foundations, Neon set-up, CI, sessions, CSRF, MFA, password reset, invitations, lockout, rate limiting, append-only audit log, user administration. Only the static role matrix is replaced by profiles.	

2. Goals and scope

- **Configurable platform:** administrators shape the CRM to their business without code: custom fields on any object, custom objects, picklists, apps, tabs, page sections, list views, reports, dashboards.
- **Complete standard apps:** Sales (leads → conversion → accounts, contacts, opportunities with pipeline), Billing (products, price books, quotes, invoices, payments), Service (cases, queues, SLAs, customer portal), Marketing (campaigns, segments, email templates, bulk sends, consent, analytics), Analytics (reports, dashboards).
- **Industry packs:** versioned bundles of objects, fields, apps, profiles, reports and server-side rules. First pack: Migration Agency (Australia).
- **Enterprise quality:** fine-grained security, full audit and field history, tests, typed API, reproducible deployment.
- **Out of scope (v1):** drag-and-drop page-layout designer, validation-rule and workflow builders, formula and roll-up fields, e-mail inbox sync, telephony, mobile apps, multi-currency, multi-tenant SaaS hosting (one deployment = one organisation). The engine leaves extension points for each.

3. Architecture: the metadata engine



Decision: every business object (standard or custom) is described by metadata and stored by one record engine. Platform tables (users, sessions, audit, profiles, metadata) stay normal relational tables.

Concern	Design
Record storage	`records` table: real columns for system fields (`id, object_id, name, owner_id, record_number, created_at/by, updated_at/by, is_deleted, version, search_vector`) plus a `data` JSONB column holding field values keyed by field API name.
Relationships	Lookup and master-detail values live in `data` and are mirrored in `record_links (from_record, field_id, to_record)` with real foreign keys, giving referential integrity, related lists and delete rules (restrict / clear / cascade).
Validation	Each write is validated against field definitions (type, required, unique, length, min/max, picklist membership, lookup target object and visibility) in the API before saving.
Indexes	GIN index on `data`; fields marked *filterable / unique / external id* get a partial expression index (`(data->>'field') WHERE object_id = …`) created by the engine with `CREATE INDEX CONCURRENTLY`; uniqueness is enforced by a partial unique index.
Numbers & money	JSONB numbers are exact decimals in PostgreSQL; the API uses Python `Decimal`. Currency fields store amounts in the organisation currency with 2 decimals.
Concurrency	`version` integer; updates must send the version read (409 on mismatch).
Recycle bin	Deletes are soft (`is_deleted`) for 30 days, restorable, then purged by a job; hard delete for admins.
History	Fields marked *track history* write old/new values to `field_history`; shown as a related list.
Business logic	Standard objects and packs register Python **object hooks** (before/after create, update, delete; custom actions such as "Convert lead"). Hooks run inside the same transaction.
Why not one table per object?	Runtime DDL for every custom field/object is slow, risky on a live database and complicates migrations. JSONB + expression indexes give the flexibility of Salesforce-style metadata with predictable operations. Limits: 200 custom objects, 400 fields per object, 25 indexed fields per object.

4. Customisation: objects, fields, relationships

Object definition

Label, plural label, API name (`invoice`, custom objects end in `__c`), icon and colour, description, name field (text or auto-number with format such as `CASE-{00000}`), record-number pattern, sharing default (section 9), feature switches: track history, allow activities, allow files, searchable, show in portal, allow reports. Standard objects cannot be deleted; their system fields cannot be removed.

Field types

Type	Options
Text / Text area / Long text	max length, default value, required, unique, external ID
Email · Phone · URL	format validation; phone stored in E.164 when parseable
Number · Percent · Currency	precision and scale, min/max, default
Date · Date/time · Time	default (today / now / blank); stored in UTC, shown in the user's time zone
Checkbox	default true/false
Picklist · Multi-select picklist	ordered values with label, API value, colour, active flag, default; optional **path** flag (drives the stage path on record pages); value-to-probability mapping for opportunity stages
Lookup	target object, delete rule (clear value / restrict), optional filter
Master-detail	parent object; child inherits sharing and is deleted with the parent
Auto-number	format with sequence, assigned on create
Address	compound: street, suburb/city, state, postcode, country

Every field also has: help text, field-level security per profile (section 9), *track history*, *filterable/sortable* (creates an index), *searchable* (adds to full-text search), and section placement on the record page. Changing a field type is allowed only between compatible types (e.g. text → long text); otherwise the admin creates a new field. Deleting a field moves it to "deleted fields" for 15 days before data is purged.

Object Manager (Setup)

Create/edit objects and fields, reorder picklist values, arrange page sections (ordered list of sections and fields — not drag-and-drop canvas in v1), choose related lists, configure compact layout (fields in the highlights panel), and list default columns.

5. Standard objects

Object	App	Key standard fields
Account	Sales	Name, type, industry, phone, website, billing/shipping address, ABN/tax ID, annual revenue, employees, parent account, owner
Contact	Sales/Service	Salutation, first/last name, account, title, email, phone, mobile, mailing address, birthdate, lead source, e-mail opt-in, do-not-call, owner
Lead	Sales/Marketing	Name, company, title, email, phone, address, source, **status (path)**, rating, industry, campaign, owner; converted flags and links

Opportunity	Sales	Name, account, primary contact, **stage (path)**, probability, amount, close date, type, lead source, next step, forecast category, owner
Opportunity Product	Sales	Product, price-book entry, quantity, unit price, discount, line total (master-detail to opportunity)
Product · Price Book · Price Book Entry	Billing	Product code, name, family, active, tax code; price books (standard + custom); list price per product per price book
Quote · Quote Line	Billing	Number, opportunity, account, contact, status (draft/sent/accepted/rejected), expiry, lines, subtotal, discount, tax, total; PDF
Invoice · Invoice Line · Payment	Billing	Number, account, contact, status (draft/issued/partially paid/paid/void), issue/due date, lines, tax, total, amount paid, balance; payments with method, date, reference
Tax Rate	Billing	Name, rate, default flag (e.g. GST 10 %)
Case	Service	Number, account, contact, subject, description, **status (path)**, priority, origin (email/phone/web/portal), type, queue/owner, SLA first-response and resolution due, closed date
Queue	Service	Name, members, objects (cases, leads); records can be owned by a queue
Campaign · Campaign Member	Marketing	Name, type, status, dates, budget, expected/actual revenue, parent; members (lead or contact) with member status
Segment	Marketing	Saved filter over contacts or leads; live count
Email Template · Email Send	Marketing	Subject, HTML/text body with merge fields; send to segment or campaign, schedule, status, delivered/opened/clicked/bounced/unsubscribed counts
Consent	Marketing	Per contact/lead and channel: opted in/out, source, timestamp, IP; unsubscribe history
Task · Event	All	Subject, type, due date / start-end, status, priority, assigned to, related to (any object), who (contact/lead); calendar
Note · File	All	Notes and attachments on any record (if enabled on the object)
Report · Dashboard	Analytics	Section 12

6. Apps, navigation and user interface

- **Layout** (as in the reference screenshots, with our own branding): narrow dark left **app rail** (Home, Contacts, Accounts, Sales, Service, Marketing, Billing, Analytics, Setup — filtered by permission), white header with logo, centred **global search**, help, setup gear, notifications bell and avatar menu; under it the **app bar**: app name followed by its object tabs (active tab underlined, tab menus for recent records and list views); light grey workspace.
- **Apps are configurable** (Setup → Apps): name, icon, ordered tabs (standard or custom objects, Home, Calendar, Reports, Dashboards), profiles that can see it.
- **Default apps:** Sales (Home, Leads, Contacts, Accounts, Opportunities, Products, Price Books, Quotes, Invoices, Calendar, Reports), Service (Home, Cases, Contacts, Accounts, Queues, Reports), Marketing (Home, Campaigns, Contacts, Leads, Segments, Email Templates, Email Sends, Consent, Reports), Billing (Products, Price Books, Quotes, Invoices, Payments, Tax Rates), Analytics (Reports, Dashboards).
- **Home pages** per app: welcome banner with getting-started cards, then cards: My Leads, My Opportunities, My Open Cases, My Tasks (with To-Do list in the footer bar), Recent Records, key dashboard charts; marketing home: setup checklist, e-mail analytics, quick actions, e-mail history.
- **Empty states** on every list: illustration, heading, one-line explanation and primary action ("Add a Lead").
- **Accessibility & responsiveness:** WCAG 2.1 AA, keyboard navigation, rail collapses into a menu below 768 px; Australian date/number formats by default, user-selectable locale and time zone.

7. List views, record pages, search, import/export

List views (every object, including custom)

- Header: object label, view name with view picker ("All Open Leads ▾"), pin as default, item count and summary line ("25 items • Sorted by Name • Filtered by Status • Updated a few seconds ago").
- Action bar: New, Import, Change Owner, Add to Campaign, Send Email, Delete (actions shown per object and permission); "Search this list…"; buttons for list settings, column chooser, refresh, sort, inline-edit mode, chart panel, filter panel.
- Columns: any field the user can read (custom fields included), resizable, sortable on sortable fields, column header menus. Filters: field / operator / value with AND/OR logic, plus "My records / All records / My team / Queue".
- **Saved views:** private, shared with everyone, or with chosen roles/profiles; default view per user. Bulk selection, mass update, mass delete, change owner; **inline edit** respecting field-level security; keyset pagination; Kanban view for any object with a path picklist (opportunities by stage, cases by status).

Record pages

Highlights panel (icon, name, compact-layout fields, actions: Edit, Delete, Clone, Change Owner, Convert, Submit…), **path** with "Mark as current/complete" for path picklists, tabs: **Details** (sections from the page layout, inline edit), **Related** (related lists generated from relationships, each with New and View All), **Activity** timeline (log call, new task, new event, e-mail, note), **History** (tracked fields).

Search, import, export

- Global search over searchable fields of every object the user can read (PostgreSQL full-text + trigram), grouped results, recent items.
- **CSV import wizard**: choose object, upload, map columns to fields (auto-match by label), duplicate rule (match on e-mail / external ID → skip, update or create), dry-run preview, background job with error file.
- **Export** of list views and reports to CSV (permission-controlled and audited).

8. Business logic of the standard apps

Area	Rules
Lead conversion	Creates or links Account and Contact, optionally an Opportunity; maps lead fields (including custom fields via an admin-defined mapping); copies activities and campaign memberships; marks lead converted (read-only afterwards). Duplicate check on e-mail and company name.
Opportunities	Stage drives probability and forecast category (editable mapping). Closed Won / Closed Lost are terminal; Closed Lost requires a reason. Amount = sum of opportunity products when products exist.
Pricing	Every product has a standard price-book entry; custom price books override list price; quote and opportunity lines pick an active entry of one price book.
Quotes → Invoices	Accepted quote can generate an invoice (lines copied). Draft invoices are editable; issuing assigns the next invoice number and locks lines. Totals: line = qty × unit price − discount; tax per line from its tax rate (GST 10 % default for Australian organisations; tax-free lines allowed); rounding half-up to the cent.
Payments	Recorded against issued invoices; status becomes partially paid / paid automatically; over-payment refused; void requires a reason and keeps history. Invoice and quote PDFs with tax-invoice fields (ABN, “Tax Invoice”).
Cases	Auto-number; assignment to queue or user; SLA due dates from priority (configurable per priority); escalation flag when overdue (scheduled job + notification); status path New → Working → Waiting on Customer → Escalated → Closed; closing requires a resolution. Web-to-case form and customer portal create cases with origin set.
Customer portal	Contacts can be invited as portal users: view and create their own cases, comment, upload files, view their invoices. Portal profile is limited by design (section 10).
Campaigns	Members from leads/contacts or segments; member status values per campaign; campaign influence on opportunities (primary campaign source); actual cost, responses, won revenue roll up by report.
E-mail sends	Recipients = segment or campaign members, minus anyone without e-mail **opt-in consent** (or opted out), hard-bounced or duplicated. Every e-mail has an unsubscribe link and the sender's identity (Spam Act 2003 / GDPR-style). Sent in batches by workers; open pixel and click redirects tracked; unsubscribe updates consent immediately.
Activities	Tasks and events attach to any activity-enabled object; reminders by notification and e-mail; calendar day/week/month views.

9. Security model: profiles, roles and sharing

Access is decided in four layers, all enforced on the server for every request, list, report, search and export.

Layer	What it controls
1. Profile — system permissions	Platform-wide abilities (table below). Each user has exactly one profile.
2. Profile — object permissions	Per object: **R**ead, **C**reate, **E**dit, **D**elete, **VA** View All (read every record regardless of sharing), **MA** Modify All (edit every record; delete every record only when D is also granted). Custom objects start with no access except for System Administrator.
3. Field-level security	Per profile and field: hidden, read-only or editable. Hidden fields are removed from API responses, list views, reports, search, exports and imports.
4. Record sharing	**Organisation-wide default** per object: Private · Public Read Only · Public Read/Write (detail objects inherit from master). Users always see records they own; the **role hierarchy** grants managers the access of their subordinates; **sharing rules** share records owned by a role/queue (or matching criteria) with another role or group (read or read/write); **manual sharing** on a record by its owner or an admin; **queue** members see queue-owned records.

Default org-wide sharing: Account, Contact: Public Read Only · Lead, Opportunity, Case, Quote, Invoice: Private · Campaign, Product, Price Book, Email Template: Public Read Only · Task/Event: Private (controlled by parent) · Custom objects: Private.

System permissions

Permission	Allows
Manage Users	Invite, edit, deactivate users; reset MFA; unlock; assign profile and role
Customize Application	Object Manager (objects, fields, picklists, page sections), apps and tabs
Manage Profiles & Sharing	Profiles, field-level security, role hierarchy, org-wide defaults, sharing rules, queues
Manage Billing Settings	Tax rates, invoice numbering and terms, company billing details, payment methods
Manage Industry Packs	Install / upgrade / disable packs
View Setup	Read-only access to Setup pages
View Audit Log	Audit trail and login history
Import Data · Export Data	CSV import wizard · export of list views and reports
Send Mass Email	Create and send e-mail sends to segments/campaigns
Manage Public Reports & Dashboards	Create/edit shared folders, reports and dashboards
Transfer Records	Change owner of records the user can edit but does not own
Manage Portal Users	Invite contacts to the customer portal, deactivate portal users
API Access	Personal API tokens for integrations

10. Default profiles and permission matrix

Eight default profiles ship with the product. Admins can clone and edit them (except System Administrator) and create new ones.

Profile	Intended for
System Administrator	IT / owner. Everything, including Setup. Cannot be edited; at least one active user must keep it.
Sales Manager	Leads the sales team; sees the team's pipeline via role hierarchy; deletes and transfers sales records.
Sales Representative	Works own leads, accounts, contacts, opportunities and quotes.
Service Agent	Works cases (own and queue), updates contacts and accounts.
Marketing User	Campaigns, segments, templates, e-mail sends, leads.
Finance	Products, price books, invoices, payments, tax rates.
Read Only (Auditor)	Reads all data and the audit log; changes nothing.
Customer Portal User	External customer contact using the portal.

Object permissions

R read · C create · E edit · D delete · VA view all · MA modify all · — none. Without VA/MA, record access follows sharing (section 9). “own” = the portal user's own contact, their account's cases they created, and invoices billed to their account.

Object	Sys Admin	Sales Mgr	Sales Rep	Service Agent	Marketing	Finance	Read Only	Portal
Account	RCED VA MA	RCED	RCE	RE	R	R	R VA	R own
Contact	RCED VA MA	RCED	RCE	RCE	RCE	R	R VA	RE own
Lead	RCED VA MA	RCED	RCE	—	RCED	—	R VA	—
Opportunity (+ products)	RCED VA MA	RCED	RCE	R	R	R VA	R VA	—
Product, Price Book	RCED VA MA	R	R	R	R	RCED	R VA	—
Quote	RCED VA MA	RCED	RCE	—	—	R VA	R VA	—
Invoice, Payment	RCED VA MA	R	R	R	—	RCE VA MA	R VA	R own
Tax Rate	RCED VA MA	R	R	—	—	RCED	R VA	—
Case	RCED VA MA	R	R	RCE	—	R	R VA	RC own
Campaign, Segment, Email Template	RCED VA MA	R	R	—	RCED	—	R VA	—
Email Send, Consent	RCED VA MA	R	—	—	RCE	—	R VA	—
Task, Event, Note, File	RCED VA MA	RCED	RCED	RCED	RCED	RCED	R VA	RC own (files, case comments)
Report, Dashboard	RCED VA MA	RCED	RC	RC	RCED	RCED	R VA	—

Object	Sys Admin	Sales Mgr	Sales Rep	Service Agent	Marketing	Finance	Read Only	Portal
Custom objects (new)	RCED VA MA	—	—	—	—	—	—	—

Notes: Sales Manager has Delete only on records they can edit through sharing (own + subordinates via role hierarchy); "RCE" never includes deleting. Finance has no Delete on invoices/payments: invoices are voided, payments reversed. Tasks/events: delete only own or subordinates' items.

System permissions by profile

Permission	Sys Admin	Sales Mgr	Sales Rep	Service Agent	Marketing	Finance	Read Only	Portal
Manage Users	✓							
Customize Application	✓							
Manage Profiles & Sharing	✓							
Manage Billing Settings	✓					✓		
Manage Industry Packs	✓							
View Setup	✓						✓	
View Audit Log	✓						✓	
Import Data	✓	✓			✓	✓		
Export Data	✓	✓			✓	✓	✓	
Send Mass Email	✓				✓			
Manage Public Reports & Dashboards	✓	✓			✓	✓		
Transfer Records	✓	✓						
Manage Portal Users	✓			✓				
API Access	✓							

Default field-level security

- All profiles: system fields read-only (created/updated by/at, record number, converted flags).
- Opportunity *Amount*, *Probability*: read-only for Service Agent and Marketing. Account *Annual Revenue*: hidden for Service Agent and Portal.
- Contact *Birthdate*: hidden for Marketing and Portal (other than own record). Payment *Reference*: visible only to Finance, Sales Manager, Read Only and System Administrator.
- New custom fields: visible and editable to System Administrator only until the admin grants access (secure by default).

Default role hierarchy

CEO → Sales Director → Sales Manager → Sales Representative · CEO → Service Manager → Service Agent · CEO → Marketing Manager → Marketing User · CEO → Finance Manager → Finance Officer. Roles (who sees whose records) are separate from profiles (what a user can do); admins edit both.

Rules on top of the matrix

- Records the user cannot see return **404**; lookups only offer visible records; related lists, reports, search and exports apply the same filters.
- Users cannot change their own profile or role, or deactivate themselves; the last active System Administrator cannot be removed.
- Portal users never reach staff APIs; staff never use portal APIs.
- Every permission, sharing and metadata change is audited.

11. Migration Agency industry pack (Australia)

An installable bundle defined as data (objects, fields, picklists, apps, profiles, report templates) plus Python hooks for rules that need code. It replaces the v2 product scope and keeps all of its features.

Component	Contents
Custom objects	**Matter** (visa case: auto-number `MAT-{YYYY}-{0000}`, client, sponsor account, visa type, stage path Consultation → Service Agreement → Document Collection → Preparation → Ready to Lodge → Lodged → Further Information → Decision, status, priority, onshore/offshore, responsible RMA, case officer, ImmiAccount TRN, lodgement date, decision date, outcome, grant number, visa expiry, fees); **Visa Type** (subclass, stream, category, default fees, checklist template); **Matter Applicant**; **Checklist Item**; **Service Agreement** (scope, fees, Consumer Guide provided, sent/signed with name, time, IP); **Client Account Transaction** (trust ledger: deposit, withdrawal, transfer to office).
Fields on standard objects	Contact: date of birth, citizenship, country of birth, passport number (encrypted, hidden by default), passport expiry, current visa and expiry, in Australia; Account: sponsor flag, sponsorship approval/expiry; User: MARA number.
App	"Migration Practice": Home, Leads, Contacts, Accounts, Matters (list + Kanban), Visa Types, Invoices, Client Account, Calendar, Reports.
Hooks (code)	Checklist generated from visa type; stage gate: past Service Agreement only with a signed agreement (admin override, audited); moving to Lodged/Further Information/Decision or recording outcome needs custom permission *Lodge Applications*; client-account balance can never go negative (row-locked); transfer to office only against an issued invoice; visa/passport/sponsorship expiry reminders.
Profiles (pack)	Practice Manager (≈ Sales Manager + Finance read + Matter VA), Registered Migration Agent (Matter RCE + VA, *Lodge Applications*, agreements), Case Officer (Matter RE via sharing: matters where they are case officer/RMA, documents, checklist), Intake Consultant (Leads RCE own, Contacts RCE, conversion), Accounts (Finance + Client Account RCE), Auditor (Read Only). Portal clients see their own matters, checklist, documents, agreements (sign) and invoices.
Compliance support	Code of Conduct workflow (written service agreement, Consumer Guide flag, fee estimates), client-money ledger with statements and reconciliation report, 7-year retention setting, Privacy Act consent fields, data in Sydney. (Supports compliance; the principal confirms against current OMARA guidance.)
Reports	Matters by stage/visa/outcome, grant rate, processing time, client-account balances, upcoming expiries, agent workload.

12. Reports and dashboards

- **Report types:** any reportable object, optionally with a related object (Accounts with Opportunities, Cases with Contacts, Campaigns with Members, custom objects). Custom fields included automatically.
- **Builder:** pick columns, filters (with relative dates such as THIS QUARTER), grouping by up to 2 rows (summary) or rows × columns (matrix), aggregates (count, sum, average, min, max), sort, chart (bar, column, line, donut, funnel, KPI). Run-time security: users only see rows and fields they may see.
- **Folders:** private, public, shared with roles/profiles. **Dashboards:** grid of report charts and KPIs with a "view as" running user and date filter; refresh on demand or scheduled.

- **Export & schedules:** CSV export (Export Data permission, audited); scheduled e-mail delivery of reports (Celery beat).
- **Standard reports:** pipeline by stage, forecast, win rate, lead conversion by source, campaign ROI, e-mail engagement, case volume/SLA compliance, aged receivables, revenue by month.

13. Data model and API

Platform tables

Group	Tables
Identity (done)	users, user_sessions, user_tokens, mfa_recovery_codes, audit_logs
Security	profiles, profile_system_permissions, profile_object_permissions, profile_field_permissions, roles (tree), sharing_defaults, sharing_rules, groups, group_members, queues, queue_members, record_shares
Metadata	object_definitions, field_definitions, picklist_values, page_layouts (sections JSON), compact_layouts, related_list_configs, apps, app_tabs, packs, pack_installations
Records	records, record_links, field_history, record_files, files (S3 keys), activities index, sequences
User experience	list_views, user_preferences (default views, pinned, recent items), notifications
Analytics	report_folders, reports (definition JSON), dashboards, dashboard_components, report_schedules
Marketing delivery	email_send_jobs, email_deliveries (per recipient status, open/click events), unsubscribe_tokens
Imports	import_jobs, import_job_errors

API (REST, `/api/v1`)

Group	Endpoints
Metadata (read)	GET /meta/objects, /meta/objects/{api}, /meta/apps — returns only what the user may see (fields filtered by FLS)
Records	GET/POST /objects/{api}/records · GET/PATCH/DELETE /objects/{api}/records/{id} · POST .../{id}/restore · GET .../{id}/related/{relationship} · GET .../{id}/history · POST /objects/{api}/records/query (filters, columns, sort, cursor) · POST /objects/{api}/records/bulk (update owner/fields, delete)
Actions	POST /objects/lead/records/{id}/convert · /quote/{id}/create-invoice · /invoice/{id}/issue · /invoice/{id}/void · /payment · /case/{id}/close · /email-send/{id}/schedule · pack actions (e.g. /matter/{id}/lodge)
List views	CRUD /objects/{api}/list-views, GET .../{id}/results
Search, files, import/export	GET /search?q= · POST /files · GET /files/{id} · POST /imports (+ status, errors) · POST /exports
Reports	CRUD /reports, POST /reports/{id}/run, GET /reports/{id}/export.csv, CRUD /dashboards
Setup	/setup/objects, /setup/objects/{api}/fields, /setup/picklists, /setup/layouts, /setup/apps, /setup/profiles, /setup/roles, /setup/sharing, /setup/queues, /setup/packs, /admin/users (done), /admin/audit-logs (done)
Portal	/portal/me, /portal/cases, /portal/invoices, /portal/files (+ pack resources)
Public	/public/web-to-lead, /public/web-to-case (CAPTCHA + rate limit), /public/unsubscribe/{token}, /public/e/{tracking}

14. Platform security, compliance, performance

- Phase 1 controls stay: hashed opaque sessions, CSRF token + Origin check, Argon2id, lockout, rate limits, TOTP MFA (mandatory for staff in production), append-only audit, security headers.
- **Query safety:** the record engine builds SQL only from validated metadata (field API names whitelisted, values bound as parameters); user-supplied filters are parsed into an AST, never concatenated.
- **Data protection:** encrypted field type for sensitive values (Fernet, key from secrets manager), S3 server-side encryption, private bucket and short-lived signed URLs, malware-scan hook for uploads.
- **Compliance:** Privacy Act 1988 / APPs and GDPR-style features — consent records, data export per person, erasure (anonymise) workflow, retention policies per object, audit and field history.
- **Performance targets:** list view p95 < 400 ms for 1 million records per object at 50 concurrent users (k6 load test); keyset pagination; expression indexes; report queries with statement timeout and row limits; heavy exports/imports in workers.

15. Testing, Neon, deployment

- **Tests:** pytest unit + API tests for every engine rule (field validation for each type, sharing calculation, FLS stripping, list-view query builder, lead conversion, pricing and tax maths, invoice states, case SLAs, consent filtering); a generated test matrix checks each default profile × object × operation against section 10; Vitest component tests; Playwright end-to-end journeys per app; load and security (OWASP ZAP) scans.
- **Neon:** unchanged from v2 — Sydney project, pooled endpoint for the app, direct endpoint for migrations, branch per pull request in CI. The Neon connector is connected to this workspace; no Neon project exists yet (to be created on approval).
- **Deployment:** Docker images (API/worker/beat, nginx SPA), GitHub Actions CI/CD, staging → production with manual approval, AWS Sydney hosting recommended.

16. Delivery phases

#	Phase	Deliverables	Estimate
0	Foundations	Done.	—
1	Identity & audit	Done (backend); login/MFA/admin UI finishing — restyled to the new layout.	—
2	Security model	Profiles, object/field/system permissions, roles, org-wide defaults, sharing rules, queues; migrate phase-1 roles to profiles; profile-matrix tests.	2 weeks
3	Metadata & record engine	Object/field definitions, all field types, validation, record CRUD, links, history, recycle bin, query builder, indexes, Object Manager API.	3 weeks
4	Lightning UI	App rail, header, apps & tabs, list views (columns, filters, saved views, inline edit, Kanban), record pages (highlights, path, details, related, activity), Object Manager & Setup UI, global search.	3–4 weeks
5	Sales app	Accounts, contacts, leads + conversion, opportunities + products, tasks/events/calendar, notes/files, import/export.	2–3 weeks
6	Billing	Products, price books, quotes, invoices, payments, tax rates, PDFs.	2 weeks
7	Service	Cases, queues, SLAs/escalation, web-to-case, customer portal.	2 weeks
8	Marketing	Campaigns, segments, templates, consent, e-mail sends with tracking, marketing home.	2–3 weeks
9	Analytics	Report builder, charts, dashboards, folders, schedules, standard reports.	2–3 weeks
10	Migration Agency pack	Pack framework + migration pack (objects, hooks, app, profiles, portal, reports).	2 weeks
11	Hardening	Load and security testing, accessibility audit, backups and retention jobs, documentation, UAT.	2 weeks

Estimates assume a small team (1 backend, 1 frontend developer, part-time QA). Each phase ends with a demo and passing CI.

17. Risks and open questions

Item	Mitigation / decision needed
Scope is large (5 apps + customisation engine)	Engine first (phases 2–4) so every app reuses it; each app ships independently.
JSONB query performance at scale	Indexed-field limits, expression indexes, load tests in phase 4 and 11.
E-mail deliverability for marketing sends	Use a provider with SPF/DKIM/DMARC and bounce webhooks (choice needed: SES, SendGrid, Postmark…).
Sharing calculations cost	Pre-computed role ancestry, indexed record_shares, query-time predicates tested for every list/report path.
Open questions	(1) Product name and branding. (2) E-mail provider. (3) Single organisation per deployment (assumed) or multi-tenant SaaS later? (4) Currency: AUD only in v1 (assumed). (5) Need for Xero/MYOB sync. (6) Should Neon project be created now in Sydney?